

THREAT MODELING AGRICAREER-TRACKER

Arief Abdul Rahman	G6401231038
Danial Akmal Mahendra	G6401231076
Muhammad Naufal Fathurrahman	G6401231094



**ILMU KOMPUTER
SEKOLAH SAINS DATA MATEMATIKA DAN INFORMATIKA
INSTITUT PERTANIAN BOGOR
BOGOR
2024**

1. PENDAHULUAN

1.1 Latar Belakang

Pengembangan aplikasi berbasis web yang melibatkan transaksi data sensitif seperti data pribadi mahasiswa, nilai transkrip, dan surat persetujuan memerlukan tingkat keamanan yang mumpuni. Dokumen ini merangkum pemodelan ancaman (threat modeling) pada sistem AgriCareer-Tracker untuk mengidentifikasi potensi celah keamanan beserta mitigasinya.

1.2 Metodologi

Kerangka kerja yang digunakan dalam menganalisis ancaman pada sistem ini adalah STRIDE, yang merupakan singkatan dari Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, dan Elevation of Privilege. Analisis ini diadaptasi secara khusus terhadap arsitektur teknologi dari AgriCareer-Tracker (FastAPI, React, SQLite, JWT, Local S3 Storage).

2. ARSITEKTUR SISTEM

2.1 Gambaran Umum Komponen

Sistem AgriCareer-Tracker berjalan menggunakan lapisan frontend yang berinteraksi dengan backend API melalui protokol HTTP/REST dan WebSocket. Secara khusus, sistem ini menyimpan state cache pengguna dalam Redis dan mengelola unggahan dokumen administrasi melalui mekanisme Local S3 Storage.

2.2 Titik Interaksi (Trust Boundaries)

Dalam analisis keamanan, terdapat beberapa titik batas kepercayaan (trust boundaries) utama:

1. Antara browser pengguna (Mahasiswa, Dosen, maupun Admin) dengan server REST API FastAPI melalui jaringan publik.
2. Antara server backend FastAPI dengan pangkalan data relasional SQLite.
3. Antara server backend FastAPI dengan layanan penyimpanan berkas (Local S3 Storage) untuk pengelolaan dokumen lampiran pengguna.

3. ANALISIS ANCAMAN STRIDE

3.1 Identifikasi Ancaman

Identifikasi ancaman pada sistem beserta skenario terjadinya dijabarkan pada Tabel 3.1 di bawah ini berdasarkan kategori STRIDE.

Tabel 3.1 Identifikasi Ancaman STRIDE

Kategori STRIDE	Potensi Ancaman	Skenario Serangan
Spoofing	Pencurian identitas JWT	Penyerang menyalin token JWT pengguna lain yang tersimpan tidak aman (misal: LocalStorage) untuk mengakses akun korban.
Tampering	Modifikasi dokumen lamaran	Penyerang memodifikasi lampiran dokumen PDF (Transkrip/LoA) saat pengunggahan sedang berlangsung.
Repudiation	Penyangkalan aktivitas	Pengguna menyangkal bahwa mereka telah memvalidasi dokumen atau mengubah status lamaran karena tidak ada bukti log.
Information Disclosure	Kebocoran data chat & profil	Endpoint API dapat diakses tanpa otentikasi sehingga data sensitif mahasiswa dan isi chat bocor ke publik.
Denial of Service	Spam koneksi WebSocket	Penyerang membanjiri server dengan permintaan koneksi chat secara simultan sehingga layanan lumpuh.
Elevation of Privilege	Eskalasi peran mahasiswa	Mahasiswa memodifikasi payload permintaan (request) untuk merubah status verifikasinya sendiri (seolah bertindak sebagai dosen).

4. STRATEGI MITIGASI

4.1 Rencana Penanggulangan

Langkah-langkah penanggulangan (mitigasi) untuk masing-masing ancaman yang telah diidentifikasi dijelaskan secara komprehensif pada Tabel 4.1.

Tabel 4.1 Strategi Mitigasi Ancaman

Ancaman	Tindakan Mitigasi yang Diterapkan
Spoofing	Penggunaan masa kedaluwarsa token JWT yang singkat (misal: 15 menit), dipadukan dengan Refresh Token yang disimpan aman. Menerapkan pengiriman token melalui HttpOnly Cookie jika memungkinkan.
Tampering	Validasi ekstensi (MIME type) dan ukuran maksimal unggahan (misal: 5MB) di tingkat backend (FastAPI). Tidak memercayai input metadata dari klien (browser).
Repudiation	Pencatatan rekam jejak (Audit Logging) yang detail untuk setiap aksi perubahan status data kritis ke dalam database yang tidak dapat dimodifikasi secara sepihak.
Information Disclosure	Penerapan Role-Based Access Control (RBAC) di setiap rute FastAPI. Endpoint harus divalidasi keabsahan token JWT-nya melalui komponen server-side.
Denial of Service	Implementasi Rate Limiter pada antarmuka REST API dan pembatasan jumlah pesan (throttling) maksimum yang dapat dikirim via WebSocket per detik.
Elevation of Privilege	Penolakan modifikasi kolom hak akses (role permissions) secara eksplisit dari API payload, melainkan diverifikasi mutlak dari payload JWT server-side.